

Seguridad de red

Una puerta abierta de par en par

Ya tienes una VPC con subredes públicas y privadas bien repartidas — la sesión pasada construiste el terreno. Pero una subred pública sin ningún filtro más es solo una puerta abierta de par en par: cualquier instancia que lances ahí queda expuesta a todo internet, en todos sus puertos, salvo que añadas algo que decida quién entra y quién no.

Hoy añades dos capas de filtrado que se confunden constantemente entre sí, y el hábito de administrar una instancia sin dejar su puerto de SSH abierto al mundo entero.

Grupos de seguridad frente a NACL

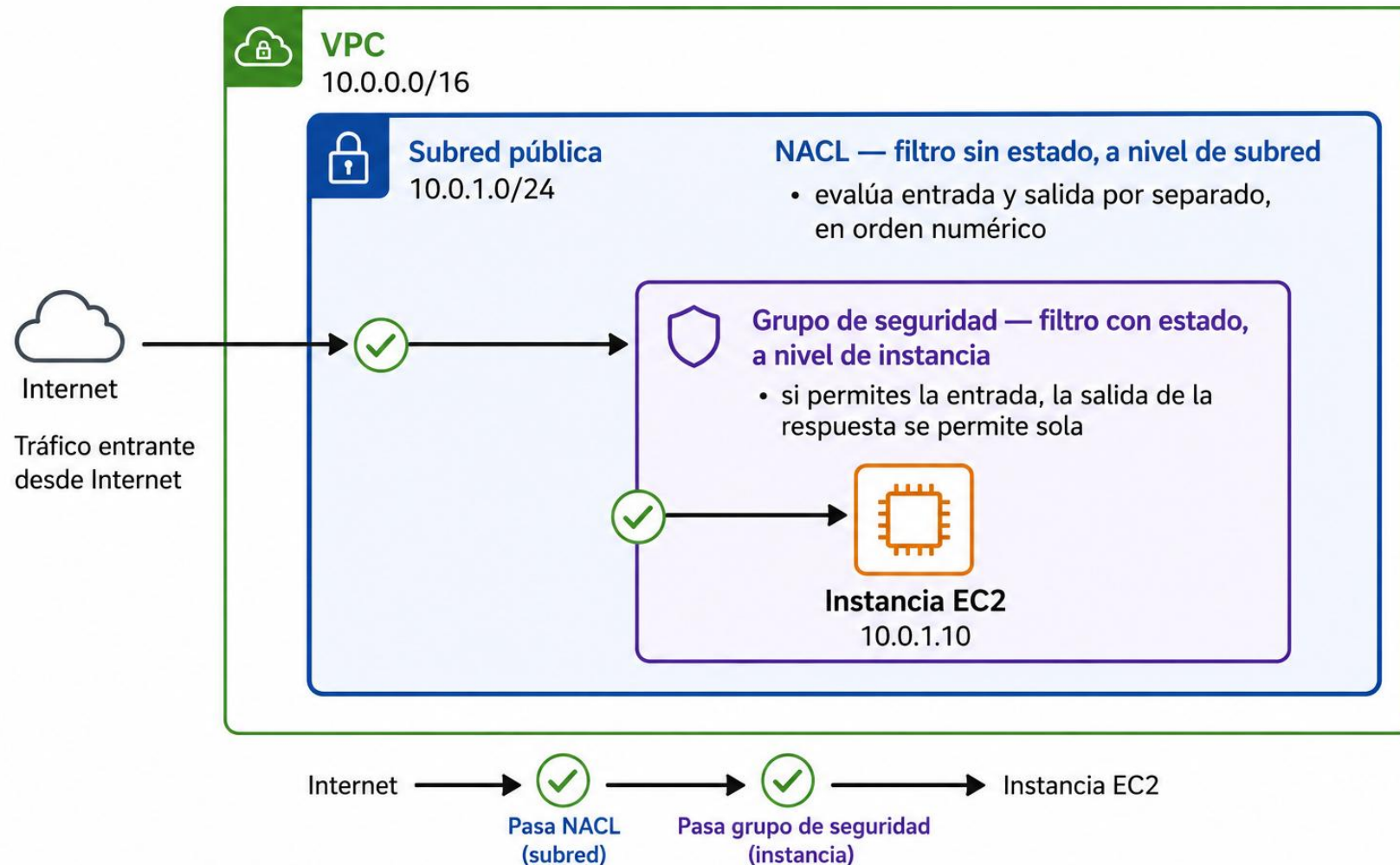
Una ACL (Access Control List) es cualquier lista de reglas que decide quién puede hacer qué sobre un recurso. La que usas hoy es la NACL (Network ACL): una ACL aplicada al tráfico de red, asociada a una subred entera de tu VPC.

	Grupo de seguridad	NACL (Network ACL)
Se aplica a	La instancia (o al recurso concreto)	La subred entera
¿Tiene estado?	Con estado: la respuesta de salida se permite automáticamente	Sin estado: hay que permitir entrada Y salida por separado
Reglas	Solo de permitir	De permitir y de denegar explícito
Orden de evaluación	Se evalúan todas las reglas que apliquen	Orden numérico: la primera que coincide gana

Las dos capas de filtrado

El portero de discoteca (grupo de seguridad) recuerda a quién ha dejado entrar. La verja del recinto (NACL) no recuerda nada: cada cruce, en cualquier sentido, se comprueba otra vez.

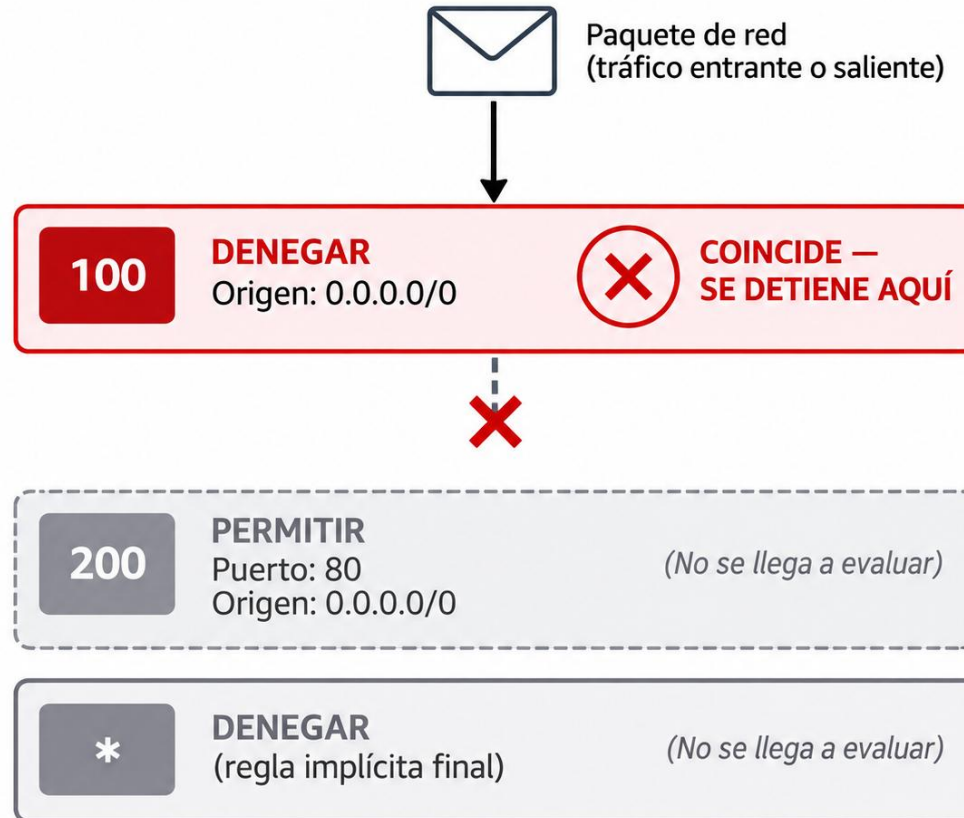
Las dos capas de filtrado: NACL (subred) y grupo de seguridad (instancia)



El orden importa: una NACL mal ordenada bloquea tráfico

Imagina una NACL con la regla 100 denegando todo desde 0.0.0.0/0, y la regla 200 —añadida después— permitiendo el puerto 80 desde ese mismo origen. AWS evalúa en orden numérico y se queda con la primera que coincide: la 100 deniega antes de que la 200 actúe.

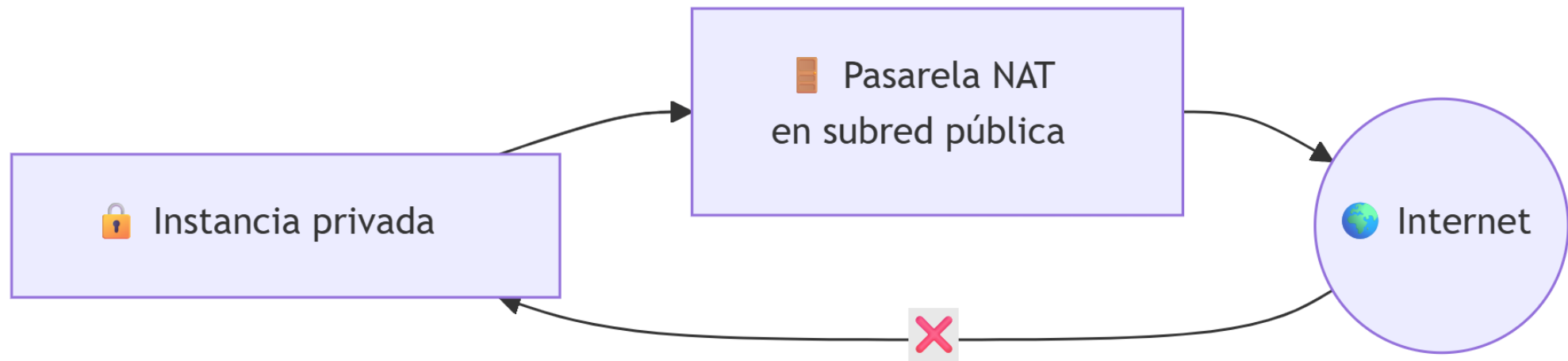
Cómo evalúa AWS las reglas de una NACL, en orden



Se evalúa en orden numérico. La primera regla que coincide gana — no importa si una regla posterior sería más permisiva.

NAT: salida a internet sin permitir entrada

Una subred privada no tiene ruta a la pasarela de internet, pero a veces necesita salir para actualizar software o llamar a un servicio externo, sin dejar de ser inalcanzable desde fuera. La pasarela NAT vive en una subred pública, y las privadas la usan como salida: el tráfico sale con la IP de la pasarela, nunca con la de la instancia privada.



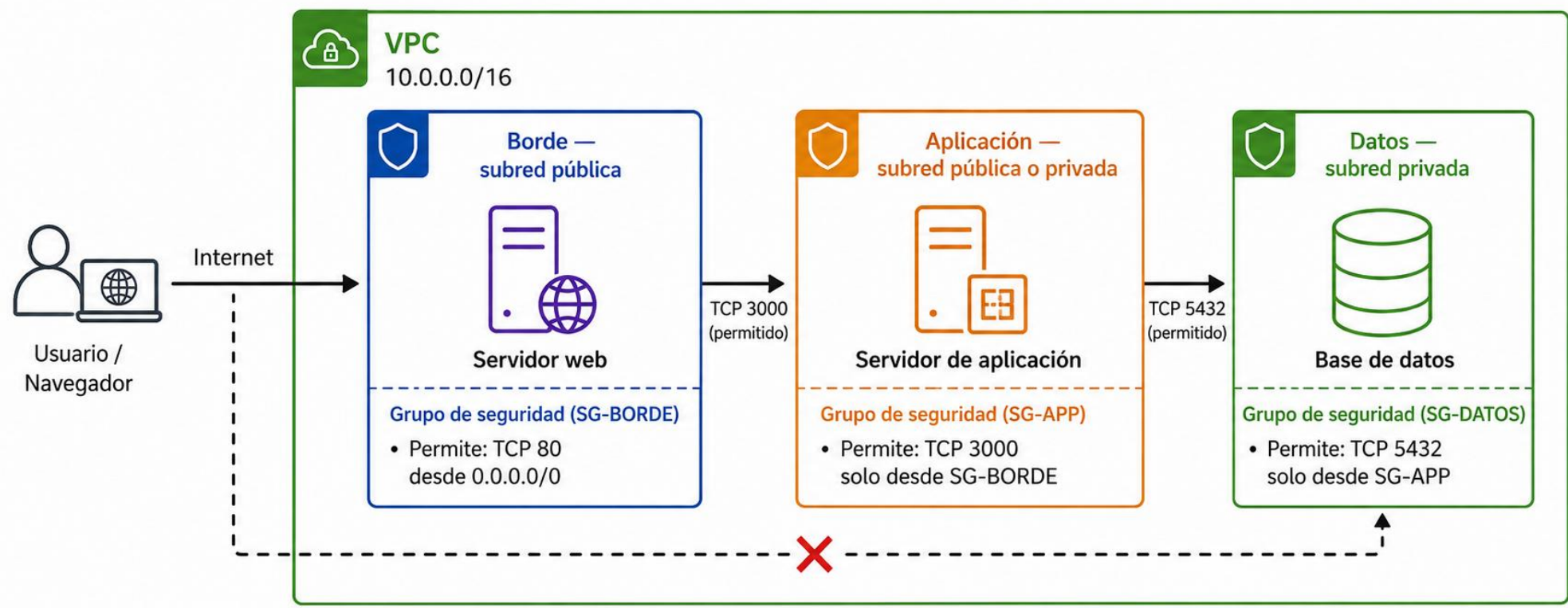
La pasarela NAT no es gratis

Se paga por horas y por GB

A diferencia de la pasarela de internet (sin coste propio), la pasarela NAT cobra por cada hora encendida y por cada GB que pasa a su través — suele ser una de las líneas más caras de una arquitectura pequeña. En la Actividad 2.2 vas a calcular su coste mensual real.

Arquitectura en capas: borde, aplicación y datos

Arquitectura en capas: borde, aplicación y datos



Puerto	Qué es
80	El puerto estándar de un servidor web.
3000	No es «oficial» de nada: lo elige el desarrollador del servidor de aplicación.
5432	El puerto por defecto de PostgreSQL — este sí es fijo.

Acceso administrativo sin exponer SSH a internet

Práctica	Qué hace	Nivel de exposición
SSH abierto a 0.0.0.0/0	Cualquier IP del planeta puede intentar conectarse	Máximo — evítalo siempre
SSH restringido a tu IP	Solo tu dirección actual puede conectarse	Bajo, pero cambia si te mueves de red
Instancia sin IP pública, acceso vía intermedia	La instancia administrada nunca es alcanzable directamente	Mínimo

Abrir el puerto 22 a 0.0.0.0/0 es de los errores más buscados por atacantes automatizados que escanean internet constantemente.

El patrón bastión, que ya usaste sin saberlo

En la Actividad 2.1 saltaste por SSH desde tu instancia pública hasta la privada, sin que la privada tuviera nunca IP pública ni una regla abierta a internet. Esa instancia de salto intermedia se llama bastión (bastion host): un único punto de entrada por SSH hacia toda la red privada.

Patrón bastión: un único punto de entrada por SSH hacia la red privada



Ideas clave

- Grupo de seguridad = filtro con estado, a nivel de instancia; NACL = filtro sin estado, a nivel de subred. Las dos capas se evalúan siempre.
- Con estado: el grupo de seguridad recuerda la conexión y permite la respuesta automáticamente. Sin estado: la NACL exige entrada y salida por separado.
- La pasarela NAT da salida a internet a las subredes privadas sin permitir entrada — y tiene coste por hora y por GB.
- Arquitectura en capas (borde → aplicación → datos): cada capa solo habla con la de al lado, nunca se salta ninguna.
- SSH nunca debe quedar abierto a 0.0.0.0/0 — restringir el origen a tu propia IP es la primera línea de defensa.